REDOUDAM INTELLIGENCE ECOSYSTEM

Operational Security Governance Systems

Comparative Reconstruction of Authority, Enforcement, Execution Evidence and ADIE Proposition

Research publication | Version 1.0 | 2 November 2026

Google Cloud • AWS • Microsoft Azure • Kubernetes • Linux • Industrial Automation

Research synthesis. External mechanisms are distinguished from engineering inference; ADIE content is a proposition, not an approved architecture.

Publication status and executive summary

Status: Research synthesis and preliminary ADIE proposition. Not an architecture approval, ADR, implementation specification, roadmap amendment, production qualification, invention declaration or patentability opinion.

Method: Each ecosystem is reconstructed through seven questions: authoritative rules; rule creation/modification/override; policy-to-enforcement path; bypasses; authority propagation; effect verification; evidence/audit. Public standards and official documentation are primary; research and cross-system conclusions are labeled.

Executive summary

Across six systems, security is not one policy document or authorization call. It is a chain of distinct states: authority definition, identity/context, policy evaluation, enforcement at a boundary, execution, observation and evidence. The systems provide mature components, but reviewed sources do not establish a universal vendor-independent guarantee spanning heterogeneous digital and physical execution with independently verified effects and complete evidence.

RedoudAm's research opportunity is to preserve attributable authority and constraints across subsystem boundaries, require local enforcement, and close operations against outcome criteria with evidence—without replacing cloud, OS, Kubernetes, API or industrial controls. This remains a hypothesis; system-level differentiation must be experimentally demonstrated.

Principal findings

Finding	RedoudAm implication
Policy, evaluation, enforcement and effect are separate.	Do not equate decision or API success with execution success.
Identity and authority are related but distinct.	Preserve accountable principal, agent/workload, delegation and resource.
Enforcement is distributed; alternate paths exist.	Subsystems retain local enforcement; inventory and test bypasses.
Logs are path-dependent and incomplete unless designed.	Evidence contracts and independent observation are essential.
Physical effect requires process-level observation.	PLC command/output is not verified physical outcome.
Existing standards/tools solve components.	Novelty cannot be claimed from component assembly alone.

1. Comparative reconstruction

System	Authority surfaces	Enforcement	Evidence	Limitation
Google Cloud	IAM; Organization Policy; hierarchy; VPC Service Controls	Service/API; perimeter	Effective policy; audit logs; resource state	Propagation delay; non-retroactivity; log category coverage
AWS	IAM/resource policies; SCP/RCP; boundaries; sessions	Service authorization; endpoints	CloudTrail; Config; service state	Policy interactions; root/management boundaries; API ≠ business effect
Azure	Azure Policy; RBAC; hierarchy; exemptions; deny assignments	Resource provider/API; deny assignment	Policy Insights; Activity Logs; Resource Graph	Audit/non-enforce modes; exemptions; compliance ≠ runtime outcome
Kubernetes	Authentication; RBAC; admission; node/runtime controls	API admission; kubelet; runtime; network	API audit; object and runtime state	Static Pods, direct node/etcd paths and indirect controller privileges
Linux	DAC; capabilities; LSM; SELinux/AppArmor; seccomp	Kernel hooks/checks; syscall filters	Audit; credentials; LSM context; runtime	Configured ≠ loaded ≠ applicable; privileged/unconfined states
Industrial OT	Asset-owner program; IEC 62443 risk/zones; engineering/safety authority	Network; workstation; PLC; HMI; safety; physical	Engineering/PLC/SCADA logs; historian; sensors	No universal enforcement point; command ≠ physical outcome

Common lifecycle abstraction



This is a comparative abstraction, not a shared implementation architecture.

Google Cloud — GCP-SG-001

Organization Policy constrains resource configuration and is distinct from IAM permission grants. Policies attach through organization/folder/project/resource hierarchy, with constraint-specific inheritance and override semantics. Effective-policy inspection provides configuration evidence, not historical proof or remediation. Propagation may take time; many constraints do not retroactively repair existing resources. Audit categories differ in enablement and coverage.

ADIE relation: snapshot rule scope/version; separate grants from constraints; model propagation, remediation and historical state.

AWS — AWS-SG-002

AWS combines identity/resource policies with SCP/RCP ceilings, permissions boundaries, session policies, trust and endpoint policies. SCPs set maximum permissions in member accounts and do not grant. Explicit deny generally overrides allow, while resource-policy/principal semantics create edge cases. Role assumption and temporary credentials propagate authority. CloudTrail records API activity; Config and service state add context, but API success is not universal outcome proof.

ADIE relation: preserve delegation chain, ceiling vs grant, resource/audience binding and policy context.

Azure — AZURE-SG-003

Azure Policy and Azure RBAC are distinct. Effects include deny, audit, modify/append, auditIfNotExists, deployIfNotExists, denyAction and disabled. DoNotEnforce, exemptions and exclusions are explicit states. Policy hierarchy and RBAC inheritance differ. Policy Insights/Activity Logs/Resource Graph help reconstruct state; current definitions do not necessarily establish historical effective policy.

ADIE relation: represent enforced/audit/exempt/disabled status and temporal policy provenance.

Kubernetes — K8S-SG-004

API flow includes authentication, authorization, mutating/validating admission, validation and persistence; controllers, scheduler, kubelet and runtime realize workloads. RBAC special bind/escalate verbs constrain privilege expansion. Static

Pods, direct kubelet APIs and direct etcd paths may bypass API admission/audit; controller-mediated creation creates indirect capabilities. API object state does not prove runtime outcome.

ADIE relation: enumerate API, node, runtime and etcd paths; correlate objects with runtime observation.

Linux — LINUX-SG-005

Linux combines DAC, capabilities, LSMs (SELinux/AppArmor), seccomp and namespaces. Active LSM, loaded policy and process context determine applicability. Unconfined AppArmor and capabilities change effective protection. Linux Audit records configured events but is not enforcement or inherently complete. Runtime credentials, LSM context and kernel state must be inspected.

ADIE relation: verify active enforcement, privilege transitions and audit scope—not merely declared profiles.

Industrial Automation — OT-SG-006

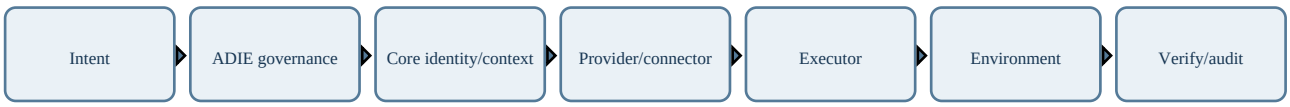
IEC 62443 frames asset-owner programs, risk assessment, zones/conduits, target security levels and system/component lifecycle requirements. Enforcement is distributed among network segmentation, remote access, engineering workstations, PLCs, HMI/SCADA, safety systems and physical controls. Cybersecurity and functional safety are complementary, not substitutes. Command acceptance, output energization, actuator movement and process change are separate states; independent measurement is needed for outcome verification.

ADIE relation: retain site/controller/safety authority; require bounded commands, interlocks, sensor freshness and process predicates.

2. Cross-system synthesis and ecosystem relations

Dimension	Observed pattern	ADIE research consequence
Authority	Layered, scoped and delegated	Separate principal, agent, delegation, resource and context
Rule state	Declared/effective/loaded/enforced/historical differ	Version/time/scope provenance; stale/unknown handling
Decision	Policy engines usually separate from enforcement	Bind decision to request and boundary
Coverage	Alternate paths and bypasses vary	Boundary inventory and bypass testing
Effect	Acceptance/persistence/runtime/physical outcome differ	Outcome predicates and independent observation
Evidence	Fragmented and configured; event ≠ effect	Correlation, integrity, completeness and gaps
Exceptions	Exemptions, emergency/privileged modes	Scope, reason, expiry, approver and post-review

RedoudAm subsystem relationship — conceptual, not approved topology



Subsystem interest	Governance relation	Verification question
Core / identity / tenant / license	Foundational identity/context; not complete dynamic authority	Who acts, for whom, on which tenant/resource and policy?
AI provider / agents	Plan/intent generator; no inherited arbitrary privilege	Provenance, tool scope, principal-agent separation
Connectors / APIs / data spaces	Adapter; local provider authorization remains	Audience/scope, transfer vs usage, result provenance
Logical executors	ADIE authority plus native enforcement	Mutation/version/deployment state independently checked
Physical executors / OT	High-consequence boundary; local safety retained	Command/output/process state and independent sensor evidence
Monitoring / evidence	Cross-subsystem reconstruction layer	Integrity, clocks, completeness and independent witness
Marketplace/modules	Registration/trust/lifecycle; listing ≠ runtime trust	Publisher/version/capabilities/revocation/conformance
NoredAm Engineering Platform	Engineering subsystem; preserve its approved/frozen boundary	Ecosystem concepts do not redesign DevTools V1

3. Public solutions and research

Open Policy Agent (OPA)/Rego

OPA is a general policy decision engine that separates policy evaluation from enforcement and supports APIs/integrations across microservices, Kubernetes, CI/CD and gateways. The caller/PEP must consume the decision; OPA alone does not guarantee boundary coverage. **Disposition:** use/adapt in controlled experiments, not as ADIE's complete authority model. [R1]

Cedar and Amazon Verified Permissions

Cedar is an authorization language with permit/forbid semantics, schema validation and automated analysis properties; CNCF accepted Cedar to Sandbox in October 2025. Verified Permissions hosts Cedar policy evaluation and integrates policy-change evidence with CloudTrail. Application enforcement remains the caller's responsibility; a hosted service is not a vendor-independent core. **Disposition:** evaluate Cedar for typed authorization; reference AWS service only. [R2–R3]

SPIFFE / SPIRE

SPIFFE provides portable workload identity (SVID); SPIRE performs node/workload attestation and issues identities based on selectors/registration. Identity authenticates a workload—it is not task authorization, user accountability or effect

verification. **Disposition:** adapt for workload identity while retaining human/agent/delegate chain. [R4]

OAuth Token Exchange and GNAP

RFC 8693 defines token exchange and delegation/impersonation. Its actor-chain elements are informational and not themselves access-control inputs. RFC 9767 extends GNAP resource-server connections. Neither provides universal cross-environment enforcement or effect proof. **Disposition:** reference/adapt, add task/resource binding and local enforcement contracts. [R5–R6]

OpenFGA / relationship authorization

Relationship models and tuples answer resource relation questions; they complement RBAC/ABAC/contextual constraints but do not automatically express all risk/runtime/effect requirements. **Disposition:** evaluate as a relationship layer, not sole authority derivation. [R7]

Agent security research (2026)

Google Research's SoK surveys 71 papers (2022–2026) and three production CVEs across input, external data, tool/protocol, memory and multi-agent layers. It identifies untrusted content acting with authority it was not granted and proposes provenance-conditioned authorization and separation of user from agent. This strongly relates to ADIE attribution/boundary concerns, but remains a survey and proposed hardening model—not universal validation. [R8]

Data sovereignty and EDC

DATAMITE D2.4/D2.5 describe EDC Control Plane/Data Plane, Dataspace Protocol, contract negotiation, transfer orchestration and policy monitoring. Implementation tests/logging are project-specific; transfer permission and post-transfer usage control are distinct. They do not prove universal sovereignty or downstream-use verification. [R9–R10]

Industrial standards

IEC 62443 zones/conduits and NIST SP 800-82 Rev. 3 provide risk-oriented OT guidance. Rev. 4 is a draft as of 2 Nov 2026, not a final replacement. Guidance does not replace site-specific safety engineering or process measurements. [R11–R13]

4. ADIE proposition — detailed (preliminary)

This proposition preserves the frozen reference: **Security Law Book** → **Dynamic Authority Derivation** → **Portable Authority** → **Independent Enforcement at Every Execution Boundary** → **Verified Effect** → **Audit.** Core is a subsystem within ADIE; participating subsystems retain domain responsibilities and local enforcement obligations. Formal architecture approval remains pending.

Proposition

ADIE could operate as a vendor-independent governance and evidence fabric for RedoudAm: derive task-scoped authority from authoritative rules and context; issue a constrained representation to a selected execution boundary; require local enforcement; and close the operation against independently observed effect criteria with attributable evidence. Differentiation depends on end-to-end proof, not component novelty.

Logical responsibility model (proposed)

Responsibility	Proposed role	Boundary
ADIE governance	Rule sources, policy lifecycle, scope/version, conflicts and approvals	Does not replace law, asset-owner or safety authority
Core subsystem	Identity, tenant/branch, foundational authorization/context	Identity/session/permission ≠ full dynamic authority/effect proof
Authority derivation	Resolve constraints; produce decision, reasons, obligations, expiry and policy version	No silent privilege expansion
Portable authority	Principal/agent/delegation; action/resource/audience; scope; expiry; nonce; revocation; integrity	Artifact is untrusted until verified at boundary
Boundary adapter	Validate artifact; invoke native controls; reject stale/unknown/mismatch	Cannot claim coverage of bypass paths
Executor/subsystem	Execute locally; return operation ID and state transitions	Retains domain logic and safety
Effect verifier	Evaluate outcome predicate using appropriate independent/fresh observation	Executor-reported success alone insufficient
Evidence/audit	Correlate intent→decision→enforcement→execution→observation →verification	Completeness must be measured and qualified

Candidate authority decision record

Group	Fields (candidate schema; not specification)
Attribution	Accountable principal; agent/workload; delegation; assurance; tenant/org
Request	Intent/request ID; normalized action; target resource; executor class; expected effect
Constraints	Law/jurisdiction; Security Law Book rule/version; organization; identity; task; resource; context; risk; runtime
Decision	Allow/deny/escalate; reason; obligations; applied constraints; policy digest; time
Authority artifact	Audience/scope/expiry/nonce; attenuation; revocation; integrity/signature
Execution	Boundary/adapter ID; local enforcement result; executor operation ID; timestamps
Outcome/audit	Predicate; observation source/freshness; measured result; verifier; evidence references; gaps

Proposed execution protocol



Protocol properties to specify

- Fail closed for unknown/stale policy, verifier outage, unknown executor or invalid evidence at high-risk boundaries.
- Effective authority is the intersection of constraints; explicit prohibition wins; subsystems cannot enlarge authority.
- Preserve accountable principal separately from agent/workload and delegates.
- Bind authority to audience, action, resource, context and time; prevent replay.

• Every execution boundary validates and enforces locally; bypass paths are enumerated/tested.
• Success requires outcome predicate evaluation; indeterminate is not success.
• Report evidence completeness/independence, not merely a green audit status.

Subsystem integration

Digital: repository/API/cloud adapter binds resource, action, branch/environment and change envelope; native permissions remain; verification inspects diff/commit/build/deployment/health.
Data: distinguish contract/transfer from downstream usage; preserve source, transformation, recipient, purpose, policy and usage evidence.
Physical: validate sensor quality/freshness; apply policy and operator/safety gate; issue bounded command to PLC/local controller; preserve interlocks; observe actuator and process independently; timeout/fault/close evidence.
AI: provider generates plan, not authority; normalize typed actions, provenance, tool scope and approvals; model confidence is not authorization.
Marketplace: publisher/version/capabilities/dependencies/signature/revocation/conformance; listing never equals runtime trust.

5. Verification plan and acceptance

Test	Experiment	Pass criterion
E1 Authorized	Scoped digital mutation	Correct binding, local enforcement, independently inspected state and linked evidence
E2 Denied	Out-of-scope/prohibited request	Boundary denies; no state change; reason reconstructable
E3 Attenuation	Delegate attempts privilege expansion	Child authority never exceeds parent; chain attributable
E4 Revocation	Expire/revoke or policy update	Defined propagation; stale artifact rejected
E5 Bypass	Direct endpoint/privileged alternate path	Blocked or detected; coverage/gap explicitly reported
E6 Physical effect	Simulated sensor→controller→actuator	Command/output/process separated; predicate independently measured
E7 Evidence fault	Missing event, skew, duplicate, tamper, source outage	Indeterminate/incomplete status; timeline and gap reconstructed
E8 Cross-subsystem	AI→connector→logical/physical executor	Attribution/constraints/correlation persist; local enforcement and outcome proof

Metrics (thresholds require formal approval)

Boundary coverage = tested enforcement paths / identified paths; authority continuity = handoffs preserving actor/delegation/decision; denial integrity = denied requests with zero unauthorized change; revocation latency measured per boundary; effect-verification coverage = operations with suitable predicate/observation; evidence completeness = required corroborated records; false-success rate target zero in controlled tests; fail-closed rate for unresolved high-risk requests.

Threats to test

Prompt injection/tool laundering; compromised connector; replay/audience mismatch; stale cache; privileged bypass; identity confusion; delegation escalation; clock skew; sensor spoofing; actuator failure; safety interlock; partial execution/rollback failure; missing/corrupted evidence; emergency override; tenant/resource confusion; policy conflict/update mid-operation.

6. Open decisions and recommended dispositions

Open decision	Reason / required evidence
Canonical Security Law Book schema	Existing policy languages do not define RedoudAm law/organization/task semantics; requires constitutional source, schema and approval.
Authority derivation semantics	Conflict/deny/exception/risk/context/time rules; formal spec, invariants and property tests.
Portable authority format	Standards may not preserve ADIE constraints; threat model, signing, revocation and interoperability tests.
Enforcement contract	Different boundaries/bypasses; inventory, adapters, conformance and failure semantics.
Independent verification	Observation may be dependent/stale/spoofed; risk-specific predicate and verifier assurance needed.
Audit completeness	No source covers every path; evidence graph, coverage, integrity and retention required.
Subsystem topology	Draft baseline pending approval; reconcile canonical sources, ADRs and roadmap.

Candidate technology disposition

Candidate	Disposition
OPA	Use/adapt in experiments as policy decision component; not Security Law Book.
Cedar	Evaluate alongside OPA for typed authorization and analysis.
SPIFFE/SPIRE	Adapt for workload identity; retain user/agent provenance.
OAuth token exchange / GNAP	Reference/adapt for delegation; add task/resource constraints and enforcement.
OpenFGA	Evaluate for relationship authorization layer.
Cloud policy services	Reference evidence; avoid core dependency consistent with cloud-independent preference.
IEC 62443 / NIST OT	Use as applicable standards references after applicability review; not generic runtime engine.

7. Conclusions and next milestone

The six reconstructions support a disciplined conclusion: authority, evaluation, enforcement, execution, effect verification and audit must be linked deliberately. Public cloud, Kubernetes, Linux and OT systems offer mature boundary mechanisms, but semantics, coverage and evidence differ. No reviewed source establishes universal portable governance with complete control and independently verified outcomes across all digital and physical environments.

ADIE's possible value is to preserve governance relationships across heterogeneous boundaries—not to replace native controls. The six-path model is a useful reference, but its formal semantics, contracts, topology and evidence requirements remain to be approved and tested. The proposition is validated only after successful and adversarial end-to-end experiments.

Next deterministic milestone

Research/engineering gate (not implementation authorization): specify a minimal ADIE experiment across one digital and one simulated/controlled physical path: authority representation, local enforcement contract, effect predicate, evidence schema, negative/bypass tests and acceptance criteria. Reconcile against constitutional sources, approved ADRs and roadmap before architecture approval or implementation.

Safe publication claims

• This report reconstructs public security governance mechanisms across six ecosystems.
• It identifies a research proposition for vendor-independent authority continuity, boundary enforcement, effect verification and evidence.
• The proposition is under investigation and is not established as a novel invention or production-qualified architecture.

8. Source register

Official documentation / standards / papers

ID	Reference
R1	Open Policy Agent docs — https://www.openpolicyagent.org/docs
R2	Cedar language reference — https://docs.cedarpolicy.com/ ; CNCF Cedar — https://www.cncf.io/projects/cedar/
R3	Amazon Verified Permissions — https://docs.aws.amazon.com/verifiedpermissions/latest/userguide/
R4	SPIFFE overview — https://spiffe.io/docs/ ; SPIRE concepts — https://spiffe.io/docs/latest/spire-about/spire-concepts/
R5	OAuth 2.0 Token Exchange RFC 8693 — https://www.rfc-editor.org/rfc/rfc8693
R6	GNAP RS Connections RFC 9767 — https://www.rfc-editor.org/rfc/rfc9767.html
R7	OpenFGA — https://openfga.dev/
R8	Google Research, SoK: Security Vulnerabilities in Agentic AI Systems (2026) — https://research.google/pubs/sok-security-vulnerabilities-in-agentic-ai-systems/
R9–10	DATAMITE D2.4/D2.5, Data Sharing and Sovereignty Mechanisms, V1.0 (2025), project-provided reports.
R11	ISA/IEC 62443 — https://www.isa.org/standards-and-publications/isa-standards/isa-iec-62443-series-of-standards ; IEC 62443-3-2 — https://webstore.iec.ch/en/publication/30727
R12	NIST SP 800-82 Rev. 3 — https://csrc.nist.gov/pubs/sp/800/82/r3/final ; Rev. 4 draft — https://csrc.nist.gov/pubs/sp/800/82/r4/ipd
R13	CISA Managing Remote Access — https://www.cisa.gov/sites/default/files/2023-01/RP_Managing_Remote_Access_S508NC.pdf

ID	Reference
R14	Google Cloud Organization Policy — https://cloud.google.com/resource-manager/docs/organization-policy/overview ; hierarchy — https://cloud.google.com/resource-manager/docs/organization-policy/understanding-hierarchy ; audit — https://cloud.google.com/logging/docs/audit
R15	AWS IAM evaluation — https://docs.aws.amazon.com/IAM/latest/UserGuide/reference_policies_evaluation-logic.html ; SCP — https://docs.aws.amazon.com/organizations/latest/userguide/orgs_manage_policies_scps.html ; CloudTrail — https://docs.aws.amazon.com/awscloudtrail/latest/userguide/cloudtrail-user-guide.html
R16	Azure Policy — https://learn.microsoft.com/azure/governance/policy/overview ; effects — https://learn.microsoft.com/azure/governance/policy/concepts/effect-basics ; compliance — https://learn.microsoft.com/azure/governance/policy/how-to/get-compliance-data
R17	Kubernetes authorization — https://kubernetes.io/docs/reference/access-authn-authz/authorization/ ; admission — https://kubernetes.io/docs/reference/access-authn-authz/admission-controllers/ ; audit — https://kubernetes.io/docs/tasks/debug/debug-cluster/audit/ ; security checklist — https://kubernetes.io/docs/concepts/security/security-checklist/
R18	Linux LSM — https://www.kernel.org/doc/html/latest/admin-guide/LSM/index.html ; capabilities — https://man7.org/linux/man-pages/man7/capabilities.7.html ; Audit — https://github.com/linux-audit/audit-userspace
P1	RedoudAm Ecosystem Current Session Reference Summary (project source; ecosystem hypotheses and boundaries)
P2	ADIE Architecture Baseline Draft 0.2.0 (project source; pending formal approval)

Governance note

This report is research-only. It informs possible future specification but cannot supersede constitutional documents, approved ADRs, architecture approval, frozen roadmaps or implementation orders. ADIE baseline draft remains pending formal approval; source/ADR/roadmap reconciliation is not assumed resolved.